

Universidad Mayor de San Andrés
Facultad de Ciencias Puras y Naturales
Carrera de Informática



INFORME PENTESTING

Semestre I/2026

Estudiante: Riveros Vera Angeles Sarai

Materia: Taller Técnico Superior

Docente: Lic. Brigida Alexandra Carvajal Blanco

Fecha: 19 de Mayo de 2026

Versión 1.0

La Paz - Bolivia

1. Resumen ejecutivo

El presente informe describe el proceso de evaluación de seguridad realizado sobre el sistema web “Spa de Mascotas”. La revisión tuvo como objetivo identificar posibles vulnerabilidades y verificar el cumplimiento de controles básicos de seguridad relacionados con autenticación, validación de formularios, gestión de sesiones y control de acceso.

La evaluación fue realizada exclusivamente mediante el análisis de una demostración en video proporcionada por los desarrolladores del sistema, sin acceso directo al código fuente, servidor, base de datos ni entorno de ejecución. Debido a ello, las observaciones y conclusiones presentadas en este informe se basan únicamente en las funcionalidades evidenciadas durante la demostración audiovisual.

Durante la revisión se verificaron mecanismos como hashing seguro de contraseñas, activación por correo electrónico, expiración de enlaces de verificación, bloqueo de intentos fallidos y auditoría de acciones. Asimismo, se identificaron aspectos que podrían fortalecerse para mejorar la seguridad general del sistema

2. Alcance de la prueba

Información general de la evaluación

Elemento	Descripción
Sistema objetivo	Sistema Web Spa de Mascotas
Tipo de sistema	Aplicación web
Tecnologías identificadas	phpMyAdmin, formularios web, autenticación por correo
Módulos evaluados	Login, registro de usuarios, gestión de sesiones y control de acceso
Funcionalidades revisadas	Activación por correo, bloqueo de cuentas, hashing de contraseñas, auditoría
Periodo de evaluación	12/05/26 al 19/05/26
Responsable del sistema	Izurieta Morales Anahi
Evaluator	Riveros Vera Angeles Sarai
Evidencia analizada	https://www.youtube.com/watch?v=JNTGo5C4qrs

3. Metodología utilizada

La metodología utilizada aplicada estuvo basada en observación funcional del sistema mediante una grabación de video proporcionada por el estudiante desarrollador. No se ejecutaron herramientas automatizadas de escaneo, explotación de vulnerabilidades ni pruebas directas sobre infraestructura real.

3.1. Recolección de información

Control observado	Estado
Registro libre de clientes	Implementado
Registro manual de empleados	No evidenciado
Activación por correo electrónico	Implementado
Seguridad de contraseñas	Implementado
Email de Activación	Implementado
Expiración de enlaces de activación	Implementado
Bloqueo por intentos fallidos	Implementado
Hashing seguro de contraseñas	Implementado
Auditoría	Implementado
Borrado lógico	Implementado
Autenticación 2FA	No evidenciado
Inicio de sesión/continuar con Google	No implementado

3.2. Observaciones adicionales

- Se evidenció la existencia de una tabla de usuarios temporales destinada a almacenar usuarios pendientes de verificación.
- No se evidenció integración con inicio de sesión o registro mediante Google.
- Se observó bloqueo de cuenta tras múltiples intentos fallidos de autenticación.
- Algunas funcionalidades fueron mencionadas como implementadas, pero no fueron demostradas completamente durante el video presentado.
- El desbloqueo de cuenta tras múltiples intentos no pudo verificarse completamente durante la demostración.

4. Hallazgos encontrados

Código	Observación	Módulo	Riesgo	Descripción	Recomendación
V-01	Ausencia de	Login	Alto	No se evidenció	Implementar

	autenticación 2FA			autenticación multifactor durante la demostración	autenticación multifactor
V-02	Funcionalidades no demostradas completamente	General	Bajo	Algunas funciones implementadas no fueron evidenciadas en la demostración	Realizar pruebas funcionales completas

Las vulnerabilidades encontradas fueron clasificadas según su impacto.

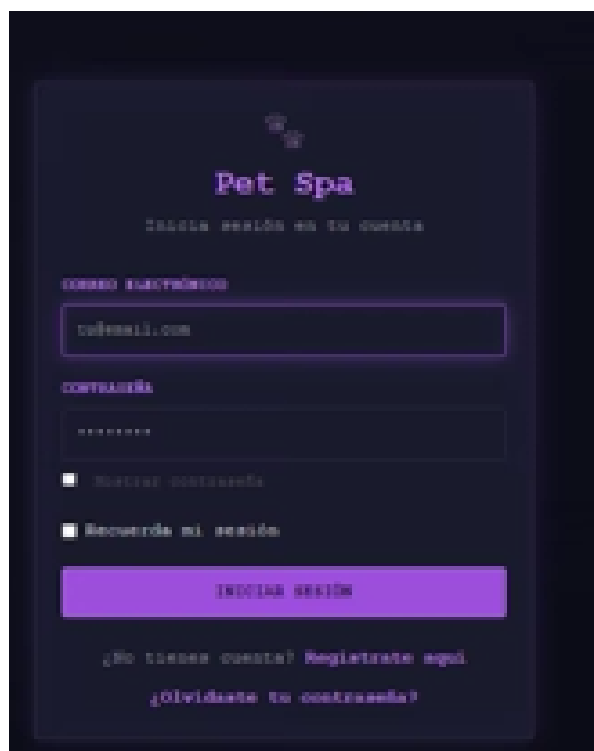
Nivel	Descripción
Alto	Vulnerabilidades que afectan la seguridad crítica
Medio	Riesgos explotables bajo ciertas condiciones
Bajo	Riesgo de seguridad baja

5. Evidencias

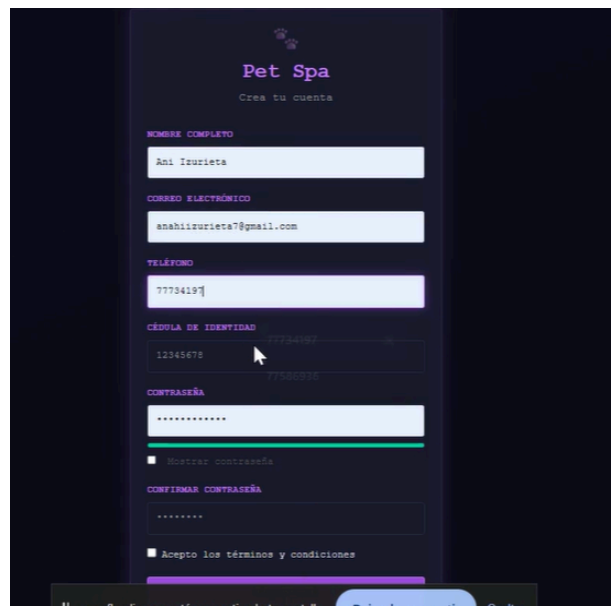
Las evidencias obtenidas corresponden únicamente a capturas extraídas de la demostración en video proporcionada por el estudiante que desarrolló el sistema.

Durante la evaluación se observaron las siguientes funcionalidades:

- Inicio de sesión



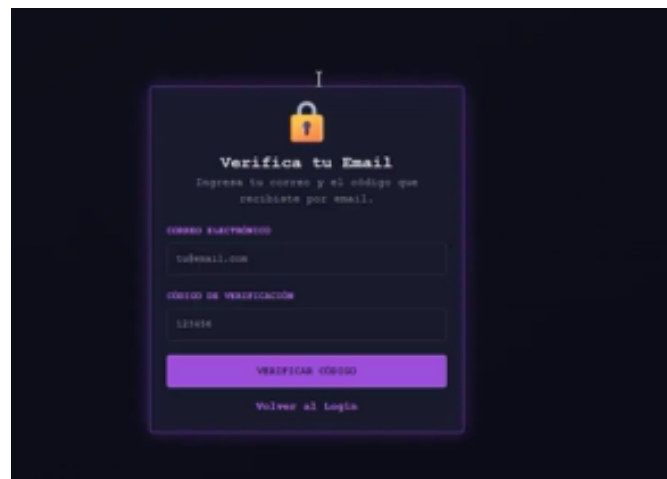
- Registro de usuarios



The screenshot shows a registration form for 'Pet Spa' with the subtitle 'Crea tu cuenta'. The form includes the following fields and elements:

- NOMBRE COMPLETO:** A text input field containing 'Aní Izurieta'.
- CORREO ELECTRÓNICO:** A text input field containing 'anahizurieta7@gmail.com'.
- TELÉFONO:** A text input field containing '7773419'.
- CÉDULA DE IDENTIDAD:** A field with two sub-inputs. The first contains '77734002' and the second contains '12345678'.
- CONTRASEÑA:** A password input field with a strength indicator bar below it.
- CONFIRMAR CONTRASEÑA:** A second password input field.
- Checkboxes:** A checkbox labeled 'Mostrar contraseña' and another labeled 'Acepto los términos y condiciones'.

- Activación de cuentas mediante correo electrónico

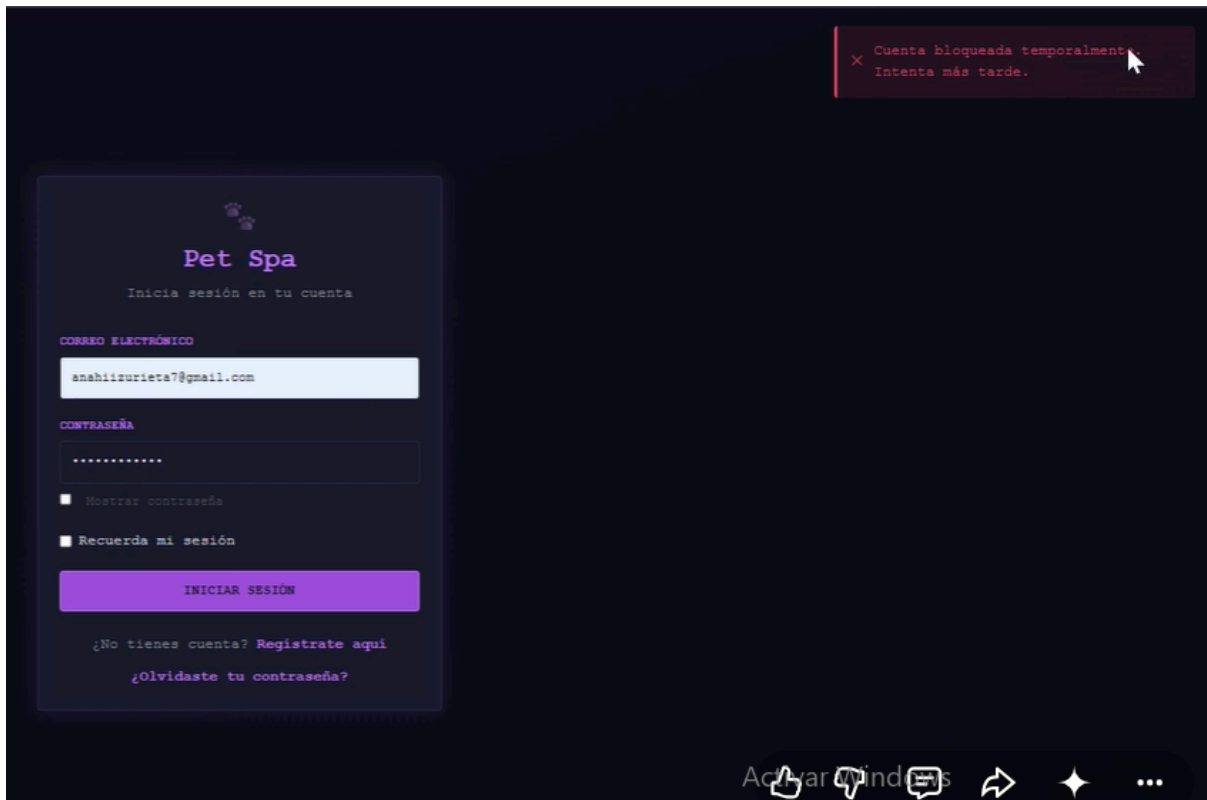


The screenshot shows an email verification form titled 'Verifica tu Email' with a lock icon. The instructions say 'Ingresa tu correo y el código que recibiste por email.' The form includes:

- CORREO ELECTRÓNICO:** A text input field containing 'tufemail.com'.
- CÓDIGO DE VERIFICACIÓN:** A text input field containing '123456'.
- Buttons:** A large blue button labeled 'VERIFICAR CÓDIGO' and a smaller link labeled 'Volver al Login'.



- Bloqueo de cuentas tras 5 intentos aullidos.



- Registro de auditoría

```
src > Models > AuditLog.php > ...
9  class AuditLog extends Model {
11
12  /**
13   * Crea un registro de auditoría
14   */
15  /** references [0 overrides
16   * public function create($data){
17   *     $idAudit = $data['id_audit'] ?? Helper::generateUUID();
18   *     $sql = "INSERT INTO {$this->table}
19   *     (id_audit, usuario_id, rol_nombre, accion, tabla_afectada, registro_id,
20   *     VALUES (?, ?, ?, ?, ?, ?, ?, ?, NOW())";
21   *     $stmt = $this->query($sql, 'ssssssss', [
22   *         $idAudit,
23   *         $data['usuario_id'] ?? null,
24   *         $data['rol_nombre'] ?? 'sin_rol',
25   *         $data['accion'],
26   *         $data['tabla_afectada'] ?? 'N/A',
27   *         $data['registro_id'] ?? null,
28   *         $data['descripcion'] ?? '',
29   *         $data['ip_address'],
30   *         $data['user_agent']
31   *     ]);
32
33   *     return $idAudit;
34   * }
```

- Gestión de sesiones.

6. Recomendaciones generales

- Implementar autenticación multifactor (2FA) para fortalecer el proceso de inicio de sesión.
- Aplicar HTTPS obligatorio en todo el sistema para proteger la transmisión de información sensible.

- Mantener políticas de contraseñas seguras, exigiendo longitud mínima y combinación de caracteres.
- Incorporar CAPTCHA en formularios de registro e inicio de sesión para reducir registros automatizados y ataques de fuerza bruta.
- Verificar que todos los módulos y rutas administrativas cuenten con validación de roles y permisos.
- Validar todos los datos ingresados tanto en cliente como en servidor.
- Evitar mostrar mensajes técnicos o errores internos al usuario final.
- Mantener registros de auditoría sobre accesos, modificaciones y acciones importantes dentro del sistema.
- Implementar expiración automática de sesiones tras periodos de inactividad.
- Realizar pruebas periódicas de seguridad y revisiones de vulnerabilidades.
- Implementar copias de seguridad periódicas de la base de datos y archivos importantes.
- Restringir el acceso directo a archivos sensibles o recursos administrativos.
- Documentar y demostrar todas las funcionalidades de seguridad implementadas durante futuras evaluaciones.
- Considerar la integración futura de autenticación mediante proveedores externos confiables como Google.
- Realizar pruebas técnicas directas en un entorno controlado para validar completamente los controles de seguridad del sistema.

7. Conclusiones

La evaluación realizada sobre el sistema web “Spa de Mascotas” permitió verificar, mediante una demostración audiovisual, la implementación de diversos mecanismos básicos de seguridad, incluyendo hashing seguro de contraseñas, activación por correo electrónico, bloqueo de intentos fallidos y auditoría de acciones.

Debido a que la revisión fue realizada únicamente mediante un video demostrativo, no fue posible ejecutar pruebas técnicas directas ni validar completamente algunos controles de seguridad internos del sistema.

A pesar de estas limitaciones, se identificaron oportunidades de mejora relacionadas con autenticación multifactor, validación de accesos y verificación de conexiones seguras mediante HTTPS. Se recomienda realizar futuras pruebas técnicas en un entorno controlado para obtener una evaluación de seguridad más profunda y precisa.